BridgeWitness

Real-time detection of cross-chain bridge exploits | CSB-01

THE PRINCIPLE

Signatures can be stolen. Conservation cannot: every destination release must consume a verified, unspent source deposit.

THE PRODUCT

An independent bridge monitor that connects exact backing checks, explainable alerts and evidence an operator can re-run.

THE DEMO

Public Nomad + Ronin attack replays, a seeded adversarial simulation, and evidence from a controlled two-chain gate demonstration.

THE AMBITION

Move from discovering theft after settlement to holding unsupported releases before execution on integrated bridges.

A valid signature is permission. A verified deposit is backing.

Basis: project PRD; generated history, detection and evidence fixtures.

Two theft patterns. One broken invariant.

Our replay explains why signatures and volume thresholds cannot be the final authority.

RONIN: LOW EVENT COUNT

Two attack releases, only 115 seconds apart. Our configured velocity detector flags 0/2; the backing rule flags both.

NOMAD: COPYCAT FAN-OUT

382 attack releases across 167 transactions and 279 recipients. The first velocity flag arrives at +2,986 seconds: 49 min 46 sec.

THE COST OF WAITING

Before that Nomad volume flag, 17 releases total about $23.59M in historical dataset value. This is observed replay exposure, not money saved.

OUR DESIGN RESPONSE

Use exact authorization and consumption rules for exploit verdicts. Use behavioral signals to rank and explain the developing incident.

The decisive question is whether the release is backed, even when its signatures look legitimate.

Local: detection.json; history.json; PRD measured-results table. Values cover the dataset subset.

Strong results, with their boundaries attached.

Historical replay + deterministic simulation + reference evidence artifacts.

382 / 382 NOMAD RELEASES

Backing violations identified from the first offending release in the replay. 0/193 normal releases flagged in the selected 1-2 August window.

2 / 2 RONIN RELEASES

Backing rule flags both historical attack releases. The configured replay volume detector flags neither.

6 ATTACKS + 2 CONTROLS

All six injected attack scenarios receive the expected exploit type. A backed whale and honest traffic burst produce no exploit verdict.

12 / 12 EVIDENCE BUNDLES

Generated fixtures record browser/Python agreement. Reference engine latency: p50 0.82 ms; p99 2.60 ms across 300 local pairs.

Replay matching validates implementation against these labels; it does not establish independent or universal detection accuracy.

Local: detection.json, history.json, evidence.json, model.json; fixture-builder assertions.

A practical stack for exact decisions.

Existing frontend in this workspace; backend and local gate demonstrated in the reference project.

OPERATOR INTERFACE

React 18 + TypeScript + Vite; React Router; Three.js / React Three Fiber for cross-chain flow inspection; Framer Motion + Lenis for presentation.

DETECTION + STATE

TypeScript BigInt accounting and replay signals today. Reference backend: Python + FastAPI; SQLite WAL for persisted events and deterministic reconciliation.

CHAIN + CRYPTOGRAPHY

EVM JSON-RPC and finalized-block scans; Solidity gate on two local Ganache chains. RLP, Keccak, Merkle-Patricia inclusion checks and canonical-JSON SHA-256.

DATA + TRIAGE

SHA-256-pinned XChainWatcher CSVs; deterministic simulation seed 2410. Reference Isolation Forest is optional advisory triage, with no containment authority.

Exact integer rules handle money. Cryptography makes supplied evidence inspectable. ML supplies bounded context.

Local: web/package.json, verify/*, fixtures; HANDOFF.md; BridgeWitness-ML-Reliability.md

Start with one operator and one route.

A focused adoption hypothesis, with no invented customers, revenue or pricing.

FIRST CUSTOMER

An EVM bridge operator with explicit deposit/release semantics and an incident-response owner. Start with one supported lock/mint or burn/release route.

LOWER-FRICTION PILOT

Run read-only beside existing infrastructure. Compare alerts with operator review, verify evidence and measure unknown coverage before granting hold authority.

PROPOSED BUSINESS MODEL

Managed monitoring subscription priced by supported routes and operational coverage; integration/support for evidence and gate workflows. Pricing is unvalidated.

WHY PAY / HOW TO VALIDATE

Potential value: less reconciliation work and reduced unsupported exposure. Interview operators, collect pilot workload data and confirm willingness to pay.

First prove that an operator trusts the evidence and uses it; then evaluate optional enforcement.

Commercial plan: team proposal. No customer interviews, paid pilots or unit-economics evidence claimed.

Trust is earned by exposing the assumptions.

These boundaries belong in the pitch, not hidden after a judge asks.

DATASET LIMIT

Historical labels derive from matching rules; replay coverage is assumed complete. Public CSVs have no signer data. Dollar values are historical dataset values.

PROOF LIMIT

Current evidence proves internal consistency and inclusion under supplied headers. State non-deposit proof integration and stronger consensus trust remain roadmap.

DEPLOYMENT LIMIT

UI defaults to fixtures; gate artifacts use local, unaudited contracts. No public-chain prevention, recovered funds or production uptime is claimed.

MODEL LIMIT

Reference forest warning recall is 9/384 = 2.34% on the held-out split. It advises only; it cannot override accounting or authorize containment.

We can defend every demonstrated result without claiming that two incidents predict every future exploit.

Local: SiteLayout.tsx NON_CLAIMS; model.json; reliability contract; architecture status.